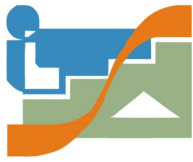


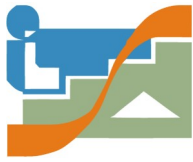
UNIT 04

Measures implementation against a Cybersecurity Incident

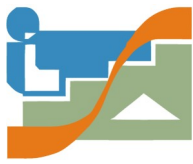




- **Develop procedures**
- **Prepare cyber-resilient responses**
- **Establish decision-making flow**
- **Tasks to restore affected services**
- **Documentation of actions taken**



- **Develop procedures**
- Prepare cyber-resilient responses
- Establish decision-making flow
- Tasks to restore affected services
- Documentation of actions taken



- **Develop detailed action procedures to respond to, mitigate, eliminate or contain the most common types of cyber security incidents**

Every year we can find web pages where the most common incidents are summarized. e.g.

<https://onlinedegrees.sandiego.edu/top-cyber-security-threats/>

<https://purplesec.us/security-insights/top-cyber-attacks-2022/>

<https://agileit.com/news/biggest-cyberattacks-2022/>

<https://www.muycomputer.com/2022/12/29/los-10-peores-incidentes-de-ciberseguridad-en-2022/>

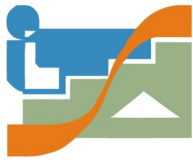
<https://www.muycomputer.com/2021/12/29/ciberseguridad-en-2021/>

<https://www.muycomputer.com/2020/12/30/ciberseguridad-en-2020/>

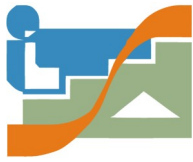
<https://www.muycomputer.com/2019/12/29/13-peores-incidentes-seguridad-2019/>



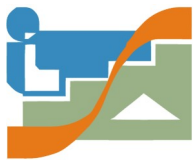
- **Social engineering**
- **Information Leak** ← <https://ermprotect.com/blog/top-10-data-breaches-so-far-in-2022/>
- **Ransomware**
- **Phishing and defacement of web pages**
- **Be part of a botnet that carries out attacks**



- **Social engineering**
 - **email security measures awareness kit**
- **Information Leak**
 - **How to manage a information leak**
 - **Information access policies**
 - **Awareness campaigns**
 - **DLP (Data Loss Prevention)**
 - **ILM (Information Lifecycle Management)**
 - **IRM (Information Rights Management)**
- **Ransomware**
 - **Don't let them hijack your computer**
- **Phishing i defacement in web pages**
 - **phishing prevention**
- **Be part of a botnet that carries out attacks**
 - **protect your company from malware**



- Develop procedures
- **Prepare cyber-resilient responses**
- Establish decision-making flow
- Tasks to restore affected services
- Documentation of actions taken



Cyber resilience: The ability of organizations or systems to recover quickly from deliberate attacks or incidents involving the use of information and communication technologies.

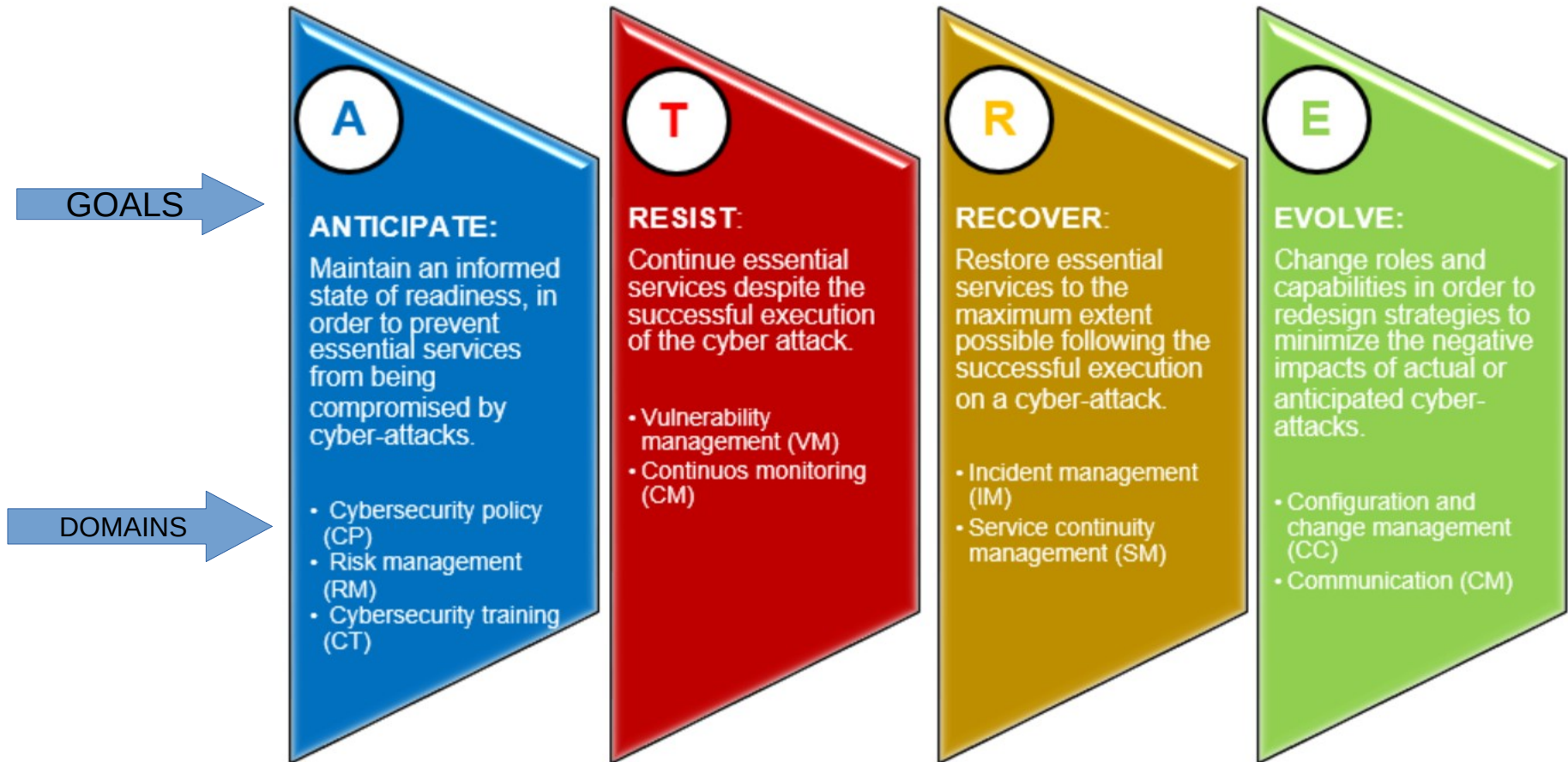
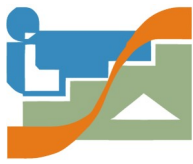
Prepare cyber-resilient responses

key to overcome incidents

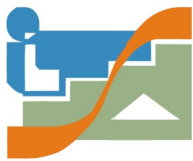
- anticipate
- Hold out
- retrieve
- evolve

CII model CII-cyberresilience-improvement-indicators -> three documents

- Evaluation Methodology
- Dictionary Indicators
- Cyber resilience form

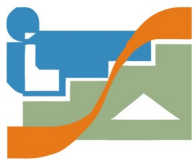


incibe-cert: context-measurement-cyberresilience-indicators-national-level



Functional Domains

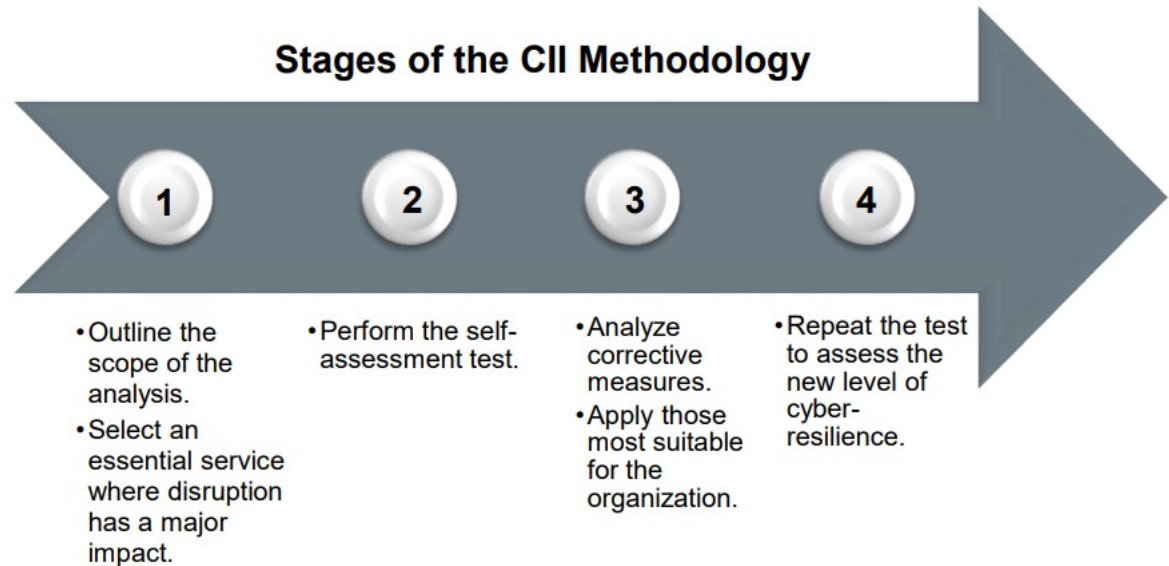
- Cybersecurity policies (CP)
- Risk Management (RM)
- Cybersecurity Training (CT)
- Vulnerabilities Management (VM)
- Continuous Supervision (CS)
- Incidents Management (IM)
- Service continuity management (SCM)
- Configuration and change management (CCM)
- Communication (CM)

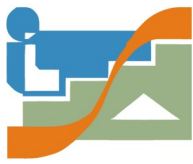


Stages of the methodology

- Delimit the supply of analysis.
- Carry out a self-assessment.
- Apply a series of corrective measures to reduce food supply.
- Repeat the self-assessment to analyze the effectiveness of the measurements.

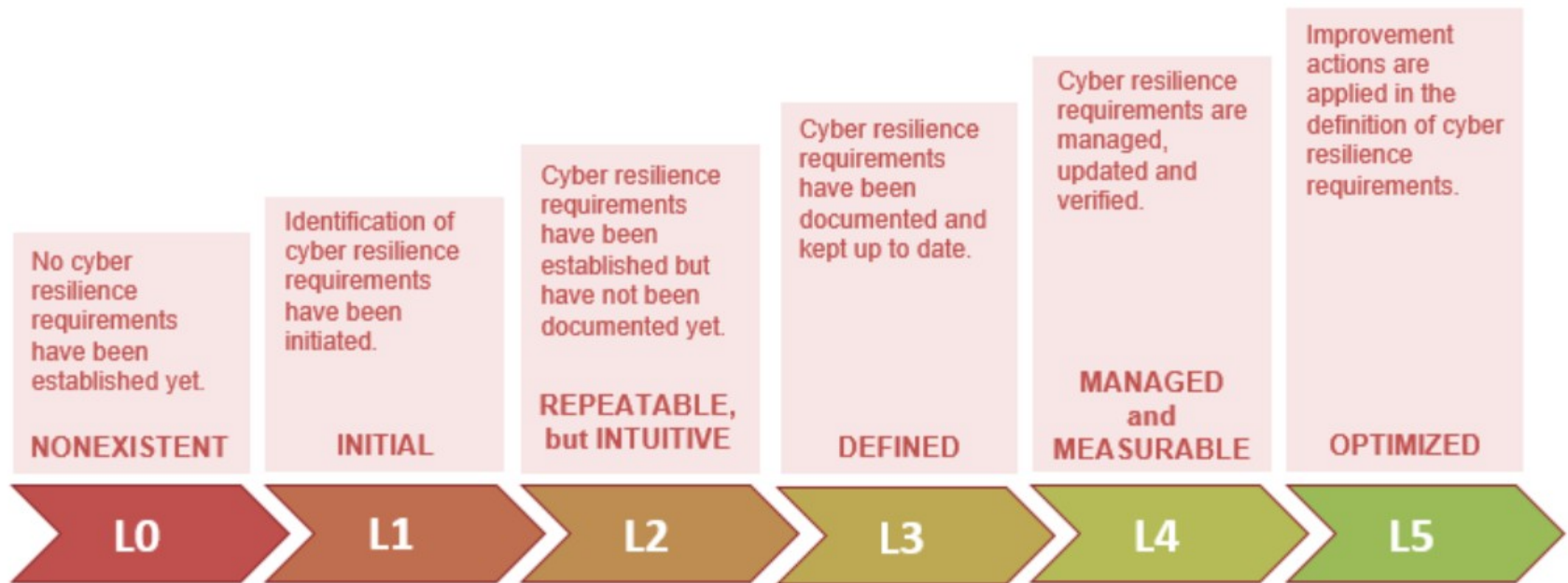
https://www.incibe.es/sites/default/files/contenidos/guias/IMC/imc_01_evaluation-methodology_2023.pdf



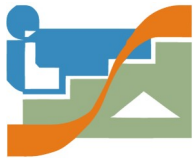


Cyber Resilience

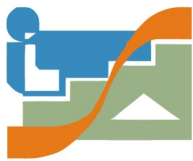
INCIBE adopts the standards of the following levels of Maturity



<https://www.incibe.es/en/incibe-cert/blog/cyber-resilience-key-overcoming-incidents>



- Develop procedures
- Prepare cyber-resilient responses
- **Establish decision-making flow**
- Tasks to restore affected services
- Documentation of actions taken



establish decision making flow

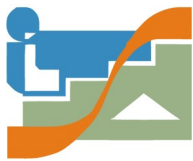
The containment strategy varies depending on the incident and the criteria must be documented to facilitate rapid and effective decisions. Some criteria that can be imprisoned on the basis are:

- Forensic Criteria.
- Bad potential i asset theft.
- Necessities for the preservation of evidence.
- Service availability.
- Time and resources to implement the strategy.
- Effectiveness of the strategy to contain the incident (partial or total).
- Duration of the solution.

[business-continuity-contingency-planning-and-disaster-recovery-whats-the-difference](#)

[plan-contingencia-continuidad-negocio](#)

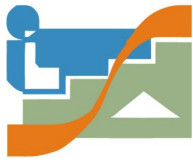
[plan_de_contingencia_y_continuidad_de_negocio.pdf](#)



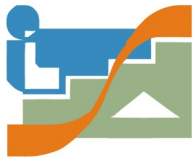
establish decision making flow

Contingency plan » Crisis plan

- It must be Practical, Operational, and Real
 - Avoid including extra information not relevant to crisis management
- It must contain
 - General information
 - Systems and critical elements
 - Personnel involved in crisis situations
 - Escalation process
 - Emergency information
 - Steps to follow
 - Disaster scenarios
- How to put it into practice
 - Detect the incident
 - Escalate and notify appropriately
 - Analyze scenarios and choose the one that applies
 - Recovery plan (technical)



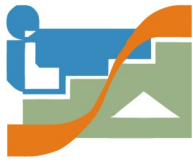
- Develop procedures
- Prepare cyber-resilient responses
- Establish decision-making flow
- **Tasks to restore affected services**
- Documentation of actions taken



Tasks to restore affected services

The purpose of the recovery phase is to return the level of operation to its normal state and that the affected business areas can resume their activity. It is important **not to rush** into production of systems that have been involved in cyber incidents.

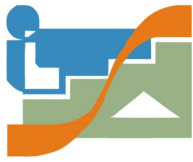
Pay special attention to these systems during production and look for any signs of suspicious activity, **defining a period of time** with additional monitoring measures.



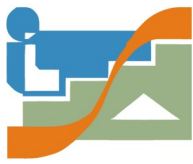
Tasks to restore affected services

do you have a disaster recovery plan?

- Develop measures for recovery
- Carry out tests
- Update and improve the plan
- Train those in charge of setting it up,
- Raise awareness and spread the plan



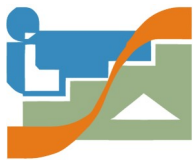
- Develop procedures
- Prepare cyber-resilient responses
- Establish decision-making flow
- Tasks to restore affected services
- **Documentation of actions taken**



Documentation of actions taken

- Description of the incident
- Determination of possible causes
- Assessment of damages and costs (impact on the organization)
- Proposed improvement measures

I-restored-the-systems-and-now ?



Documentation of actions taken

Documenting everything that happened will help us understand the incident and evaluate the actions taken. With this we can learn from our mistakes and reinforce good practices in case it happens again and to try to avoid it in the future. The documentation must include:

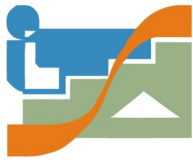
Description of the incident.

- What date and time the incident was identified.
- Type of incident: Ransomware, data leakage, denial of service, etc.
- Resources affected, how badly and how it affected the company.
- Record if it was necessary to stop services, notify customers or suppliers, etc.
- What actions were taken to solve it, when were they carried out and why was it done that way.
- Evidence collected throughout the process, for example emails received, or encrypted files or disk drives.

Possible origin Indicate what could have been the origin of the incident based on all the steps in the previous two articles. It will also be recorded if it has already been resolved.

Staff involved. All the people who have participated in one way or another in the resolution of the incident must be appropriately identified.

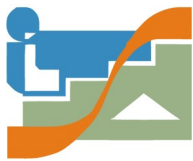
Date and time of resolution of the incident. A sequential record of performances must be kept.



Documentation of actions taken

Assess the damages and costs of the incident

- Replacement of equipment or its software
- Reputational damage due to, for example, disclosure of confidential information
- legal
- Those associated with the recovery of normal activity and analysis of the incident
- Those due to downtime.



Documentation of actions taken

Review Company Policies: **Lessons Learned**

- What went wrong to cause the incident?
- Which security policy didn't work?
- What needs to be improved so it doesn't happen again?
- Have I informed the employees of what happened?
- Is it necessary to train employees so they know how to act in these cases?
- Was the handling of the incident correct?
- What steps can be improved to make incident management smoother?
- If the incident had to be made public, was communication with the media correct and fluid?
- Was there an exercise of transparency with public opinion or, on the contrary, were the communications opaque?
- If the incident affected private information of customers or suppliers, was the communication carried out within the deadline and in the appropriate form?